AHMADU BELLO UNIVERSITY, ZARIA

FACULTY OF ENGINEERING

DEPARTMENT OF COMPUTER ENGINEERING

COEN838: ADVANCED SOFTWARE ENGINEERING

Project Examination, Question 4

OFFLINE-FIRST CRYPTOGRAPHIC QR IDENTITY WALLET

FOR RURAL PUBLIC SERVICES

TECHNICAL REPORT

Document QRW-TR-07 · Version 1.0

BY

ALIYU SARKI ILIYASU

P25EGCP8040

November 2026

DOCUMENT CONTROL

Document details

Item	Detail
Document	Technical Report (QRW-TR-07)
Project	Offline-First Cryptographic QR Identity Wallet for Rural Public Services
Course	COEN838 Advanced Software Engineering, Ahmadu Bello University, Zaria
Author	Aliyu Sarki Iliyasu (P25EGCP8040)
Version / date	1.0 · November 2026
Source code	https://github.com/sarki94/qr-identity-wallet
Related documents	QRW-SRS-01 · QRW-SDD-02 · QRW-SEC-03 · QRW-TST-04 · QRW-PRM-05 · QRW-USR-06

Revision history

Version	Date	Change
1.0	4 Nov 2026	First complete technical report

TABLE OF CONTENTS

1. INTRODUCTION 1
1.1 Summary 1
1.2 Purpose and Structure of This Report 1
1.3 References 2
2. ASSUMPTIONS 3
3. ENGINEERING PROCESS 5
3.1 Overview and Timeline 5
3.2 Requirements Engineering (Module I) 5
3.3 Architecture and Design (Module III) 6
3.4 Security Engineering (Module IV) 6
3.5 Implementation 7
3.6 Testing and Quality Assurance (Module II) 8
3.7 Project and Risk Management (Module V) 8
3.8 Tools and Automation 8
4. RESULTS 9
4.1 Requirements 9
4.2 Testing and Quality 9
4.3 Demonstration 9
5. DISCUSSION 10
5.1 How the Design Answers the Problem 10
5.2 Key Trade-offs 10
5.3 Lessons Learned 10
6. LIMITATIONS AND FUTURE WORK 12
6.1 Limitations 12
6.2 Future Work 12
7. ETHICAL, LEGAL AND SOCIAL CONSIDERATIONS 13
8. STATEMENT ON THE USE OF AI 14
8.1 Tool Used 14
8.2 What the AI Did 14
8.3 What the Candidate Did 14
8.4 Safeguards 15
9. CONCLUSION 16

1. INTRODUCTION

1.1 Summary

Rural citizens in Nigeria are often turned away from public services because online NIN verification fails where there is no network. This report describes how a solution to that problem was engineered for COEN838 Question 4: an offline-first cryptographic QR identity wallet, applied to the collection of subsidised fertiliser in Kura Local Government Area, Kano State.

The system issues each farmer a digitally signed credential at the LGA office, carried as a QR code in a wallet app on the farmer's phone or printed on paper. At the distribution point the agent's phone verifies it with no network: it checks the issuer's Ed25519 signature, asks the wallet to sign a fresh challenge to prove it is not a copy, checks revocation and expiry against a cached signed list, and asks the agent to compare the farmer's face. Every check is queued and later uploaded to a hash-chained audit log. The prototype consists of a cryptographic core library, five services and one progressive web app. It meets 43 of its 48 requirements in full and 5 in part; 94 automated test cases (145 checks) pass; and the dynamic security scan ends with no high- or medium-risk finding.

1.2 Purpose and Structure of This Report

The examination asks for a technical report describing the engineering process followed (Instruction B) and stating every assumption made in interpreting the problem (Instruction D), and requires responsible and ethical use of AI (Instruction F). Section 2 states the assumptions. Section 3 describes the engineering process, phase by phase, and Section 4 the results. Section 5 discusses the design and what was learned, and Section 6 the limitations and future work. Section 7 covers ethical, legal and social considerations, and Section 8 is the statement on the use of AI. The detailed artefacts are in the six companion documents listed in Table 1.1.

Table 1.1: Submission documents

Code	Document	Main content
QRW-SRS-01	Software Requirements Specification	Elicitation, FR/NFR, UML models, formal specification, RTM
QRW-SDD-02	Software Design Document	Architectural style, components, ERD, communication patterns, scalability
QRW-SEC-03	Security Engineering Report	STRIDE threat model, principles, authentication, security testing
QRW-TST-04	Test Plan and Test Report	Strategy, test cases, results, coverage, defects
QRW-PRM-05	Project, Risk and Maintenance Plan	Process, earned value, risk register, maintenance plan
QRW-USR-06	User Manual and Installation Guide	Installation, user guide by role, troubleshooting
QRW-TR-07	Technical Report (this document)	Process, assumptions, results, AI-use statement

The source code, build instructions, UML sources, test evidence and the generators for all seven documents are in the GitHub repository https://github.com/sarki94/qr-identity-wallet.

1.3 References

African Farming. (2026). *Katsina launches fertiliser scheme to strengthen 2026 farming season*. https://africanfarming.net/crops/agriculture/katsina-launches-fertiliser-scheme-to-strengthen-2026-farming-season

Fältström, P., Ljunggren, F., & van Gulik, D.-W. (2022). *The Base45 data encoding* (RFC 9285). Internet Engineering Task Force. https://doi.org/10.17487/RFC9285

Josefsson, S., & Liusvaara, I. (2017). *Edwards-curve digital signature algorithm (EdDSA)* (RFC 8032). Internet Engineering Task Force. https://doi.org/10.17487/RFC8032

Nigeria Data Protection Commission. (2023). *Nigeria Data Protection Act, 2023*. Federal Republic of Nigeria.

Nwaobiala, C. U., & Ubor, V. U. (2019). Effectiveness of electronic wallet system of Growth Enhancement Support Scheme distribution among arable crop farmers in Imo State, South-Eastern Nigeria. *Scientific Papers Series Management, Economic Engineering in Agriculture and Rural Development, 16*(1).

Sommerville, I. (2016). *Software engineering* (10th ed.). Pearson.

2. ASSUMPTIONS

Instruction D requires every assumption made in interpreting the problem to be stated. They fall into two groups: how the problem statement was interpreted (Table 2.1), and the operating assumptions the design depends on (Table 2.2, also in QRW-SRS-01 Section 2).

Table 2.1: Assumptions in interpreting the problem

ID	Assumption	Reason
IA1	"Rural public services" is interpreted through one concrete service, the collection of subsidised fertiliser, with clinic attendance as a secondary use case that uses the same mechanism.	The problem statement names both; a concrete case was needed for real requirements, and it matches the author's own observation.
IA2	"Offline-first" means that verification at the point of service works with no network. Enrolment and issuance happen online at an LGA office.	Issuance must consult NIMC and protect the signing key, which cannot be done safely on a field device.
IA3	The credential proves identity only (who the farmer is), not entitlement (how much fertiliser, whether already collected).	Entitlement and distribution are the subject of Question 3; keeping them separate keeps the identity layer reusable for clinics.
IA4	BVN is not used and is not placed in the credential.	Identity is anchored on the NIN; adding banking data to a QR seen by every agent would breach data minimisation.
IA5	"Wallet" means a holder-controlled app on a phone; a printed paper wallet is an extension for farmers without a smartphone.	The question names a wallet; the elicitation found feature phones and shared phones common.
IA6	A progressive web app is acceptable as the "app".	It runs offline, installs to the home screen and uses the camera, without app-store distribution.
IA7	Mock NIMC data and demonstration accounts are acceptable for an examination prototype.	Real NIMC access is licensed; no real personal data was used.

Table 2.2: Operating assumptions and dependencies

ID	Assumption	Consequence if false
AS1	NIMC is represented by a mock service with fictional records; production integration requires NIMC licensing.	The Issuer calls the real NIMC interface; no change to credentials or verifiers.
AS2	The issuer signing key is held in an encrypted file in the prototype; production would use a hardware security module.	Key-compromise risk rises (risk PD-2).
AS3	L2 holders have an Android phone (own or shared) with a camera; all others use the L1 paper wallet.	More L1 use, lower assurance.
AS4	Agents are given an Android smartphone by the programme.	Verification cannot run at that point.
AS5	Distribution points obtain at least intermittent connectivity within seven days.	Revocations arrive later; the 30-day refusal rule applies.
AS6	Entitlement (quantities and collection status) is managed by a separate programme system.	Scope would extend into Question 3.
AS7	Proxy collection is prohibited by programme policy, as observed in Kura.	A delegation feature would be needed.
AS8	Enrolment takes place at an office with connectivity.	Offline issuance would need a different key-protection design.

3. ENGINEERING PROCESS

3.1 Overview and Timeline

The project followed an iterative process: requirements and models first, then implementation in daily increments, each ending with a tested build, with documentation generated from the repository at the end. Table 3.1 summarises the timeline; earned-value tracking is reported in QRW-PRM-05.

Table 3.1: Project timeline

Date	Phase	Main outputs
22 Oct 2026	Problem choice and requirements	Question 4 chosen (D1); course formats gathered from the lecture notes; first requirements and service split (D3)
25 Oct 2026	Elicitation and modelling	Elicitation localised to Kura LGA; two assurance levels (D2a); UML use case, sequence, class and state models
30 Oct 2026	Detailed design and core	Credential format (D9), test strategy (D10); core library built test-first; CI pipeline
3 Nov 2026	Services, web app, security	Five services; the progressive web app; security tests and hardening; generated RTM; candidate's local setup and first push; CI green on GitHub
4 Nov 2026	Verification and documentation	OWASP ZAP scan and fix; browser coverage; SRS, design, security, test, project and user documents
5–7 Nov 2026	Validation and defence	Phone test, this report, review, slides and rehearsal

3.2 Requirements Engineering (Module I)

The course's elicitation techniques were compared for this problem (QRW-SRS-01, Table 2.1). Ethnography, in the form of direct non-participant observation, was chosen as the primary technique because the problem lives in a physical, low-literacy setting where much of the knowledge is tacit. The author had observed manual fertiliser distribution in Kura LGA during the 2024 wet season as a non-participant observer; that observation was written up and triangulated with published evaluations of the GES e-wallet scheme (Nwaobiala & Ubor, 2019) and reports of current state schemes (African Farming, 2026). Nine findings were recorded, each traced to the requirements it produced. Three of them changed the design: proxy collection is discouraged (so the system enforces holder presence), phones are often shared (so one wallet holds several PIN-protected profiles), and many farmers have feature phones (so a paper wallet exists).

The requirements were classified into 29 functional and 19 non-functional requirements (performance, security, capacity and usability, as in the course), prioritised with

MoSCoW and modelled with a use-case diagram, three sequence diagrams, a domain class diagram and two state machines, one of which is also given as a formal state-transition function. Traceability was designed in from the start: every test names the requirements it verifies, and a script generates the four-column RTM (requirement, UML artefact, code module, test case with result) from the code and the test results.

3.3 Architecture and Design (Module III)

The decisive design question was where the trust decision happens. Any architecture that asks a server at the moment of verification fails the problem statement, so trust was moved to the edge with digital signatures: the verifier needs only the issuer's public key and a recent signed revocation list. The back end was then split into services on trust and availability boundaries rather than on screens: Auth (staff identity), Issuer (the only holder of the signing key), Trust and Revocation (publishes keys and the signed list), Audit and Sync (collects records into a hash chain), and a mock NIMC. Each service has its own database. Communication is synchronous where an officer is waiting, asynchronous and batched where phones synchronise, and entirely offline between wallet and verifier. A message broker and container orchestration were rejected because they serve no requirement and would cost days. QRW-SDD-02 gives the full comparison of styles, the ERD, the communication patterns and the scalability and failure-mode analysis.

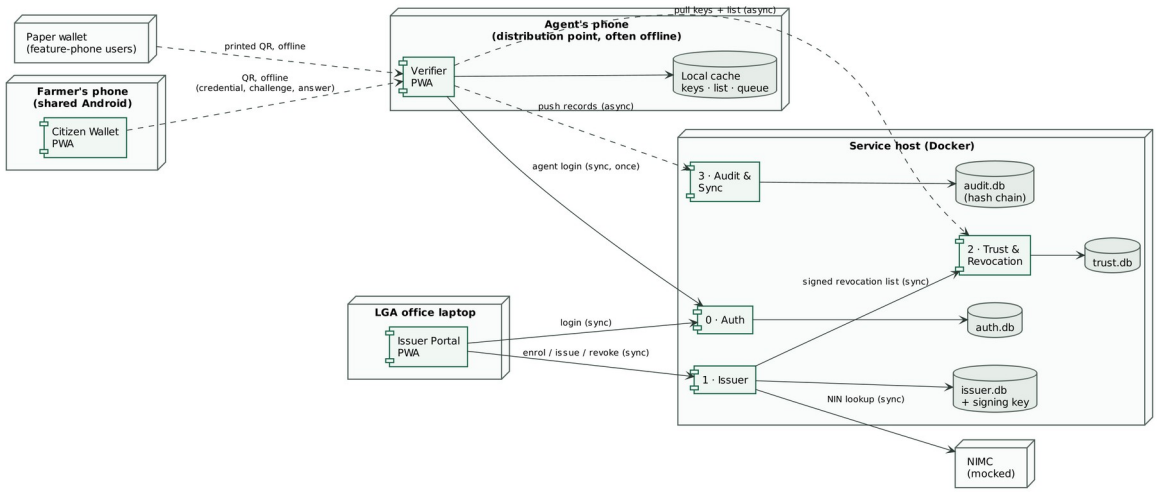


Figure 3.1: Component and connector view of the system

3.4 Security Engineering (Module IV)

Security was designed in from the first model. The threat model applies STRIDE to each trust boundary of the data-flow diagram and found nineteen threats; each has a mitigation

and a verifying test. The design applies least privilege (only the Issuer holds the signing key; services verify tokens with Auth's public key and cannot mint them), defence in depth (four independent checks on every farmer) and failing securely (every error is a rejection, property-tested on random input). Staff authenticate with scrypt-hashed passwords, lockout, rate limiting and short-lived EdDSA-signed tokens with role-based access control; farmers authenticate offline by device key, PIN and face. Security testing combined static analysis (Bandit), dependency scanning (pip-audit, npm audit), black-box security tests and an authenticated OWASP ZAP scan; QRW-SEC-03 reports all of it.

3.5 Implementation

The implementation reuses a stack the author already uses professionally (Python with FastAPI; React with TypeScript and Vite), which reduced risk under a tight deadline. Table 3.2 summarises the code base.

Table 3.2: Implementation summary

Part	Technology	Notes
qrw_core	Python 3.11+, cryptography	Signing and verification, Base45 QR format, challenge–response, revocation list, hash chain; pure functions, no I/O
Services	FastAPI, SQLAlchemy, PyJWT, SQLite (PostgreSQL ready)	Five services, one Docker image, Compose file, local launcher
Web app	React 18, TypeScript (strict), Vite, @noble/ed25519, Web Crypto	Wallet, Verifier, Issuer Portal, Audit, Guided Demo; offline service worker
Tooling	pytest, Hypothesis, Vitest, Playwright, Bandit, Flake8, pip-audit, OWASP ZAP, GitHub Actions	Tests, scans and CI; RTM and documents generated by scripts
Size	About 2,400 lines of production code	24 commits from 30 October 2026, with red and green test-first commits

Two design choices made the cross-platform implementation reliable. The issuer signs the exact payload bytes rather than a re-serialised object, so Python and the browser never disagree about what was signed; and the browser uses strict RFC 8032 verification, so it accepts exactly the signatures the server would. Both are proven by test vectors generated in Python and checked in the browser on every push.

3.6 Testing and Quality Assurance (Module II)

The test strategy follows risk. The core library was built test-first, with the failing suite committed before the implementation; property-based tests prove security properties over generated inputs (for example, flipping any single bit of a credential always causes rejection); cross-implementation tests make the browser and Python agree; the services are tested black-box through their APIs; and two Playwright system tests drive the real application on three simulated devices, including fully offline verification. Continuous integration runs linting, static analysis, dependency audits, all automated tests and coverage gates on every push. QRW-TST-04 lists every test case and its result.

3.7 Project and Risk Management (Module V)

Work was planned in story points against a baseline, with a cut list agreed in advance. When three planned days passed without sprint work the schedule performance index fell to 0.25; the plan was corrected by pulling work forward and cutting staff multi-factor authentication and the full Hausa translation, and the index recovered to 0.95. Eleven risks were registered with exposure RE = P × L, none in the red tier, and a maintenance plan classifies seventeen anticipated changes as corrective, adaptive, perfective or preventive (QRW-PRM-05).

3.8 Tools and Automation

The course distinguishes upper-CASE tools for requirements and models from lower-CASE tools for code, analysis, build and test. Here the models are PlantUML sources kept in the repository; the requirements catalogue is a Python module; the RTM, the test-case catalogue, the charts and all seven documents are generated by scripts from the repository, so a change to a requirement, test or result flows into the documents when they are rebuilt. This kept the documentation consistent with the working system, which is the property the examiners' note on documentation without a working system is concerned with.

4. RESULTS

4.1 Requirements

Of the 48 requirements, 43 are implemented in full and 5 in part: FR-14 (agent PIN unlock of the offline token not built), FR-27 (staff multi-factor authentication deferred), NFR-S3 (TLS only between phones and the app in the prototype), NFR-S8 (data-protection procedures such as recorded consent are organisational) and NFR-U1 (Hausa limited to the verdicts). All 48 are linked to at least one passing test or a recorded manual verification.

4.2 Testing and Quality

Table 4.1: Key results

Measure	Result
Automated test cases / checks	94 / 145, all passing
Browser system tests	TC-SYS-002 11/11; TC-SYS-003 16/16
Statement coverage	Core 97%; services 97%; browser verifier 90%; PIN vault 100%
Defects found during development / open	7 / 0
OWASP ZAP (after fix)	0 High, 0 Medium, 1 Low accepted
Static analysis and dependency scans	No open findings
Offline verification time	0.32 ms (Python), 4.3 ms (browser library); budget 3 s
100,000-entry revocation list	0.94 MB compressed in transit; 1.41 MB in the phone cache; budget 2 MB
Schedule performance index (4 Nov)	0.95, recovered from 0.25

4.3 Demonstration

The system can be demonstrated in two ways. The Guided Demo runs the whole distribution day on one laptop, step by step, against the live services; it was run by the candidate on his own Windows laptop on 3 November with every step passing, and it is the planned demonstration for the oral defence. For a field-style demonstration, the same application runs on real phones over HTTPS on a local Wi-Fi network (QRW-USR-06, Section 4.3).

5. DISCUSSION

5.1 How the Design Answers the Problem

The problem is not that verification is slow, but that it depends on a network that is often absent. Moving the trust decision onto the agent's phone removes that dependency completely for the moment that matters, while keeping the properties an online check would give: forgery is prevented by the signature, copying by the challenge–response, withdrawal by the revocation list, and impersonation by the face check. What cannot be achieved offline is instant revocation; the design makes that gap explicit, bounds it with list-age rules, and shows it honestly in the Guided Demo (step 13) rather than hiding it.

5.2 Key Trade-offs

- **Revocation freshness against availability.** Refusing all checks when the list is old would make the system useless where it is most needed; accepting forever would make revocation meaningless. The 7-day warning and 30-day refusal are a stated compromise.
- **Inclusion against assurance.** The paper wallet admits farmers without smartphones at a lower assurance level; every acceptance records its level so the trade-off can be monitored.
- **Simplicity against scale.** No broker or orchestrator was used. Because verification runs on phones, server load comes only from batched synchronisation, so the simpler architecture does not limit scale in the way it would for an online design.
- **Policy in software.** Proxy collection is prohibited by the programme; the system enforces that rule rather than offering delegation, which a different programme might want.

5.3 Lessons Learned

- **Field evidence changes designs.** The original concept was a smartphone-only wallet; the observation of shared and feature phones produced multi-profile wallets and the paper wallet.

- **Agree formats across languages early.** Signing exact bytes and generating shared test vectors on the first day avoided the most likely source of late, hard-to-find defects.
- **Manual testing still matters.** The most serious defect (DEF-01, valid codes rejected because the scanner trimmed meaningful spaces) was surfaced by the candidate's own hands-on testing, not by the automated suite; it now has regression tests.
- **Scanners find what tests miss.** The OWASP ZAP scan found a missing security header on the API documentation pages that no test had looked for.
- **Plan for slippage.** The cut list, agreed before it was needed, turned a schedule crisis into a set of known, documented deferrals.

6. LIMITATIONS AND FUTURE WORK

6.1 Limitations

- Elicitation rests on a single observer's retrospective observation in one LGA and season, triangulated with published sources; no structured interviews or usability tests with farmers and agents were carried out.
- The prototype uses a mock NIMC, SQLite and a file-based signing key; production needs NIMC integration, PostgreSQL and a hardware security module.
- Performance was measured on a test machine; a field trial on low-end Android phones in Kura has not yet been done.
- Five requirements are only partly met, as listed in Section 4.1.

6.2 Future Work

In order of value: a field pilot with agents and farmers, including a think-aloud usability evaluation of the Verifier; staff multi-factor authentication and the full Hausa interface; delta revocation lists small enough for SMS or USSD to shrink the revocation gap; storing the farmer's signed answer for non-repudiation; and, for production, NIMC integration, an HSM and a data protection impact assessment. These are scheduled in the maintenance plan (QRW-PRM-05, Section 5).

7. ETHICAL, LEGAL AND SOCIAL CONSIDERATIONS

- **Privacy and data protection.** The design follows the minimisation and purpose-limitation principles of the Nigeria Data Protection Act 2023: the credential carries a masked NIN and no BVN, telephone number or date of birth; the full NIN is never stored; audit records hold credential identifiers, not personal details. Recorded consent at enrolment and a data protection impact assessment are required before any real deployment.
- **Inclusion.** Farmers without smartphones are not excluded: they receive a paper wallet. Shared family phones are supported with separate PIN-protected profiles. Verdicts are shown in Hausa as well as English, with colour and icons for low-literacy users.
- **Fairness and human oversight.** The face check is made by a person, not an algorithm, so no biometric model with possible demographic bias decides who receives fertiliser. Rejections are recorded with their reason so that wrongful refusals can be reviewed.
- **Honest evidence.** No field data was invented. Personas are labelled as illustrative composites; all test data is fictional; every performance figure is measured by a test in the repository; and partial requirements are reported as partial.

8. STATEMENT ON THE USE OF AI

Instruction F requires responsible and ethical use of AI. In keeping with that, this section states plainly how AI was used, what the candidate did, and how the work was checked.

8.1 Tool Used

Claude, an AI assistant made by Anthropic, was used throughout the project as a working collaborator, in a series of sessions directed by the candidate. All AI-assisted commits in the repository carry a Co-Authored-By trailer naming the assistant, so its involvement is visible in the version history.

8.2 What the AI Did

- Discussed and critiqued options with the candidate: the choice of question against the marking rubric, the architecture, the security design and the test strategy.
- Drafted the elicitation write-up from the candidate's account of his observation in Kura and from general knowledge of the context; the candidate then checked, corrected and localised it.
- Wrote most of the source code and tests, and drafts of the UML models and all seven documents, under the candidate's direction.
- Ran the automated tests, coverage, static analysis, dependency audits and the OWASP ZAP scan in its own workspace, and fixed the defects found.
- Prepared step-by-step guides that the candidate used to set up the project on his own laptop and GitHub.

8.3 What the Candidate Did

- Chose the question and the case study, and supplied the field observation from Kura LGA (2024 wet season) on which the requirements rest.
- Made or approved every significant decision recorded in the decision log, including the two assurance levels, the ban on proxy collection, the separate documents and the department writing style.

- Gathered the lecturer's formats for the SRS, RTM, STRIDE table, risk register and UML from the course materials, so that the artefacts follow the course rather than generic templates.
- Set up and ran the system on his own laptop, published it to GitHub, ran the Guided Demo end to end, and through that hands-on testing surfaced the scanner defect DEF-01.
- Reviewed the documents and is responsible for the submission and its oral defence.

8.4 Safeguards

- **Verification by tests, not trust.** AI-written code was accepted only when it passed the automated tests, coverage gates and scans in CI; claims in the documents are backed by measured results in the repository.
- **No fabricated evidence.** The AI was not used to invent field observations, interviews, users or measurements. Where evidence did not exist, the documents say so (for example, the phone field test is reported as pending).
- **Transparency.** AI involvement is declared here and in every AI-assisted commit.
- **Understanding.** The candidate asked for explanations of each design choice and worked through an interactive walkthrough of the protocol, so that he can explain and defend the design, security and testing choices orally.

9. CONCLUSION

The project set out to let a rural farmer prove who he is when the network fails. The engineered solution does that by moving trust to the edge with signed credentials, binding each credential to its holder with an offline challenge–response, and keeping accountability through a tamper-evident audit trail that synchronises when it can. It was built with the methods of the course: ethnographic elicitation and traceable requirements, a justified offline-first service architecture, STRIDE-based security engineering with layered defences, test-driven development with property-based, cross-implementation and system testing in continuous integration, and managed risk and maintenance. The prototype runs, its claims are tested, and its limits are stated. The next step is a field pilot in Kura.